

Bloque 09_examenes

Índice de módulos

- Examen de Active Directory
- Examen final integrador
- Examen de fundamentos
- Examen de Linux
- Examen de seguridad web
- Examen de Windows

Examen de Active Directory

1. Explica dominio, principal, DC, LDAP, SMB, Kerberos y NTLM.
2. Distingue AS-REP roasting y Kerberoasting por precondiciones y material obtenido.
3. Diferencia Pass-the-Hash y Pass-the-Ticket.
4. Interpreta una arista BloodHound sin tratarla como impacto confirmado.
5. Explica ACL GenericAll, WriteDACL y límites de alcance.
6. Diagnostica errores de DNS, realm y desfase horario Kerberos.
7. Describe qué valida AD CS antes de afirmar una plantilla abusiva.
8. Analiza password spraying con bloqueo y reglas de alcance.
9. Propón mitigaciones para tickets, ACL y AD CS.
10. Escenario: credencial de usuario, SPN, ccache y trust. Construye una ruta explicable, pruebas mínimas, criterios de parada y evidencia.

Rúbrica

Fundamentos 20; precondiciones 30; ruta/evidencia 30; alcance y mitigación 20.

Examen final integrador

Duración: 4 horas de laboratorio y 2 horas de informe.

Escenario

Un entorno autorizado contiene una web pública, un host Linux, un host Windows unido a dominio y una red interna no accesible directamente. Se entregan salidas parciales con una pista falsa por bloque.

Entregables

1. Alcance y supuestos.
2. Mapa de superficie.
3. Registro cronológico de observación, hipótesis, prueba y resultado.
4. Confirmación de al menos una técnica web y una local.
5. Diseño de pivoting con flujo de retorno explicado.
6. Análisis de una ruta AD sin ejecutar cambios persistentes.
7. Dos payloads contruidos por capas y una adaptación fallida razonada.
8. Informe con evidencia, impacto, mitigación y limitaciones.

Rúbrica

Criterio	Puntos
Metodología y gestión del tiempo	20
Precisión técnica	20
Construcción/adaptación de pruebas	20
Evidencia y falsos positivos	15
Cadena de impacto dentro de alcance	10
Mitigaciones	10
Informe y reproducibilidad	5

Se aprueba con 70 puntos, ningún bloque crítico bajo 50 % y sin violación de alcance.

Examen de fundamentos

Duración: 90 minutos. Sin solucionario durante el intento.

1. Descompón una URL con esquema, autoridad, puerto, path, query y fragmento.
2. Distingue cookie, sesión, autenticación y autorización.
3. Interpreta Content-Type: application/json con un cuerpo de formulario y predice la capa del error.
4. Explica encoding, canonicalización y cifrado con un ejemplo de cada uno.
5. Diferencia shell, proceso, binario, biblioteca, parser e intérprete.
6. Predice el orden de expansión, splitting y redirección en una línea Bash sencilla.
7. Modela source, transformación, validación y sink en una consulta SQL concatenada.
8. Construye una prueba mínima verdadera/falsa sin extraer datos.
9. Propón mitigación para validación textual de una URL destinada a petición servidor.
10. Escenario: una API recibe query, cookie y JSON. Dibuja todos los parsers y diseña cuatro controles que cambien una sola entrada.

Rúbrica

Criterio	Puntos
Precisión conceptual	30
Modelo de capas y parsers	25
Pruebas mínimas y controles	25
Mitigaciones causales	20

Examen de Linux

1. Explica usuario real/efectivo y cómo SUID modifica el modelo.
2. Interpreta una salida `sudo -l` con regla y entorno.
3. Compara `sudo`, SUID y capabilities.
4. Identifica precondiciones de cron, PATH y wildcard injection.
5. Diagnostica por qué un binario SUID no conserva privilegios.
6. Explica el riesgo de grupos Docker/LXD/disk.
7. Decide cuándo un exploit de kernel es justificable.
8. Propón mitigaciones para dos vectores sin usar “bloquear comando”.
9. Construye una tabla observación-hipótesis-prueba para NFS `no_root_squash`.
10. Escenario: usuario de servicio, cron root, script no escribible y módulo Python escribible. Demuestra la ruta mínima, controles, impacto y restauración.

Rúbrica

Mecanismos 25; precondiciones 25; pruebas y evidencia 30; mitigación y limpieza 20.

Examen de seguridad web

Duración: 120 minutos. Laboratorio autorizado.

1. Diferencia IDOR, autenticación débil y control client-side.
2. Interpreta tres respuestas de una prueba SQL booleana y descarta un falso positivo.
3. Construye una prueba de command injection para un contexto `sh -c` y contrástala con `argv`.
4. Explica una ruta traversal por niveles y su normalización.
5. Diseña confirmación y control negativo para SSRF HTTP.
6. Separa aceptación, almacenamiento, servicio y ejecución en un upload.
7. Adapta una prueba SSTI cuando la expresión aparece literal.
8. Propón mitigaciones para SQLi, SSRF, LFI y upload.
9. Analiza una petición JSON con JWT y un identificador de objeto; prioriza pruebas.
10. Escenario práctico: discovery revela `/api`, upload y parámetro `url`. Construye un plan de ocho pasos, evidencia esperada, criterios de descarte y una cadena de impacto sin exceder la primitiva confirmada.

Rúbrica

Criterio	Puntos
Identificación y mecanismo	25
Construcción razonada	30
Adaptación y falsos positivos	20
Evidencia, impacto y mitigación	25

Examen de Windows

1. Interpreta `whoami /priv` sin asumir que todo privilegio está habilitado.
2. Explica servicio, cuenta de servicio, binario y ACL.
3. Determina condiciones de un `unquoted service path`.
4. Contrasta `AlwaysInstallElevated` y DLL hijacking.
5. Analiza credenciales guardadas y su validación segura.
6. Explica token impersonation y su precondition.
7. Distingue UAC de frontera de seguridad completa.
8. Diseña pruebas para tareas programadas y autoruns.
9. Propón mitigaciones para servicios y registro.
10. Escenario: WinPEAS señala tres hallazgos. Prioriza, descarta dos falsos positivos y demuestra uno con evidencia de identidad efectiva.

Rúbrica

Modelo de permisos 30; interpretación 20; prueba mínima 30; mitigación 20.